Auxin

Security that empowers you

CONFIDENTIAL : NOT TO BE SHARED

End-to-End Agentic AI Security Architecture and GRC

Auxin Security
Omer Farooq
October 2026



Updated 8 minutes ago

Nvidia unveils AI security push, boosts share buyback by $150B

Share

Edited by **Emma W. Thorne**, Editor at LinkedIn News

Nvidia on Monday debuted a new artificial intelligence security system meant to stop agents from going off-task. The Open Agent Safety Platform consists of two open-source tools, OpenShell and Sentry, that can "quarantine a suspicious agent in milliseconds," said Justin Boitano, who leads Nvidia's enterprise AI efforts. In a LinkedIn post, CEO Jensen Huang declared, "This is... the beginning ... see more

Top perspectives

Jensen Huang • 3rd+
Founder and CEO, NVIDIA
11h • Edited •

+ Follow ···

Today, with over 100 industry partners, we introduced the NVIDIA Open Agent Safety Platform, bringing together OpenShell and Sentry.

Artificial intelligence is extraordinary technology that will advance discovery, productivity, security, health, and prosperity for generations to come. But its full promise can only be realized when people have confidence that AI is being built to be safe and deployed with wisdom and responsibility.

NVIDIA Open Agent Safety Platform Reference Design combines NVIDIA OpenShell and NVIDIA Sentry. OpenShell is an open-source secure runtime that gives AI agents clear, enforceable boundaries. It traces their actions and enforces policy as they work. NVIDIA Sentry delivers added layer of security with hardware-based enforcement on NVIDIA BlueField, continuously monitoring agent activity through a trusted telemetry and detection pipeline and enabling millisecond-scale containment and quarantine.

This is bigger than a single product. It's the beginning of an open ecosystem to build the trust layer for safe agent systems. Together, we are building the foundation of the AI economy.

Trust and innovation are not in conflict. Safety is how trust is earned. We must build not only the most capable AI, but the most trusted AI, so that this extraordinary technology can realize its enormous promise for the world. https://nvda.ws/4hOkDx7



CONFIDENTIAL, NOT TO BE SHARED

Auxin



Omer Farooq · 2nd

Hands-on AI, Cloud, Cybsecurity Architect | GRC | Agentic, GenAI, MLOps - LangChain, LlamaIndex, Foundry, Vertex, SageMaker, Bedrock | 8x Cloud Cert Azure GCP AWS, DevSecOps | Speaker @ RSA DEFCON SIGGRAPH | Founder-Exit

Auxin Security

Harvard Kennedy School

CONFIDENTIAL: NOT TO BE SHARED

Let's Connect on LinkedIn

Auxin

Roadmap

1 — 2 — 3 — 4

CHAPTER 1

GenAI & Agentic AI Architecture

Architecture and data-focused

- Data flow & RAG
- Agent architecture
- Reference architecture
- Cloud service mapping

CHAPTER 2

GenAI & Agentic AI Security as an Architect

Zero Trust, threats & attack paths

- Security gaps
- Agent identity & ASI Top 10
- Zero Trust across stack
- Threat modeling

CHAPTER 3

Security as Developer

Building, testing & monitoring

- Secure agent runtime
- Sandboxing & permissions
- Tracing & observability
- Drift detection

CHAPTER 4

Security as GRC

Governing & observing Agentic AI

- Agent estate & ownership
- Guardrail policy
- Risk-tier behaviour
- Evidence & compliance

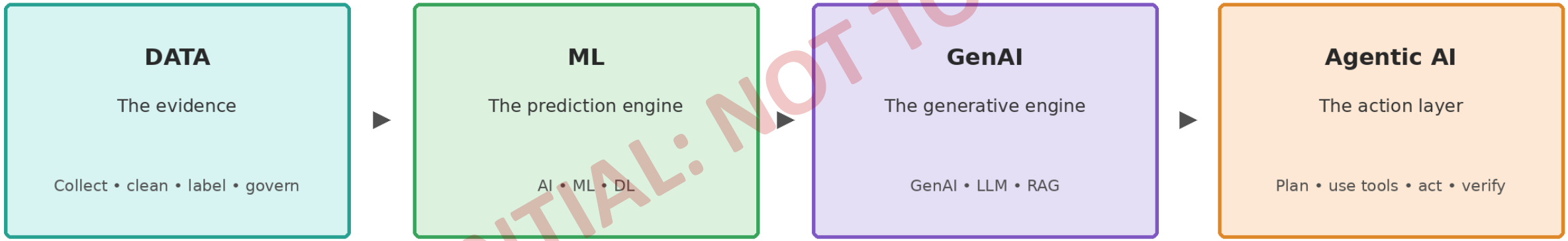


Architecture Focus

CONFIDENTIAL: NOT TO BE SHARED

Auxin

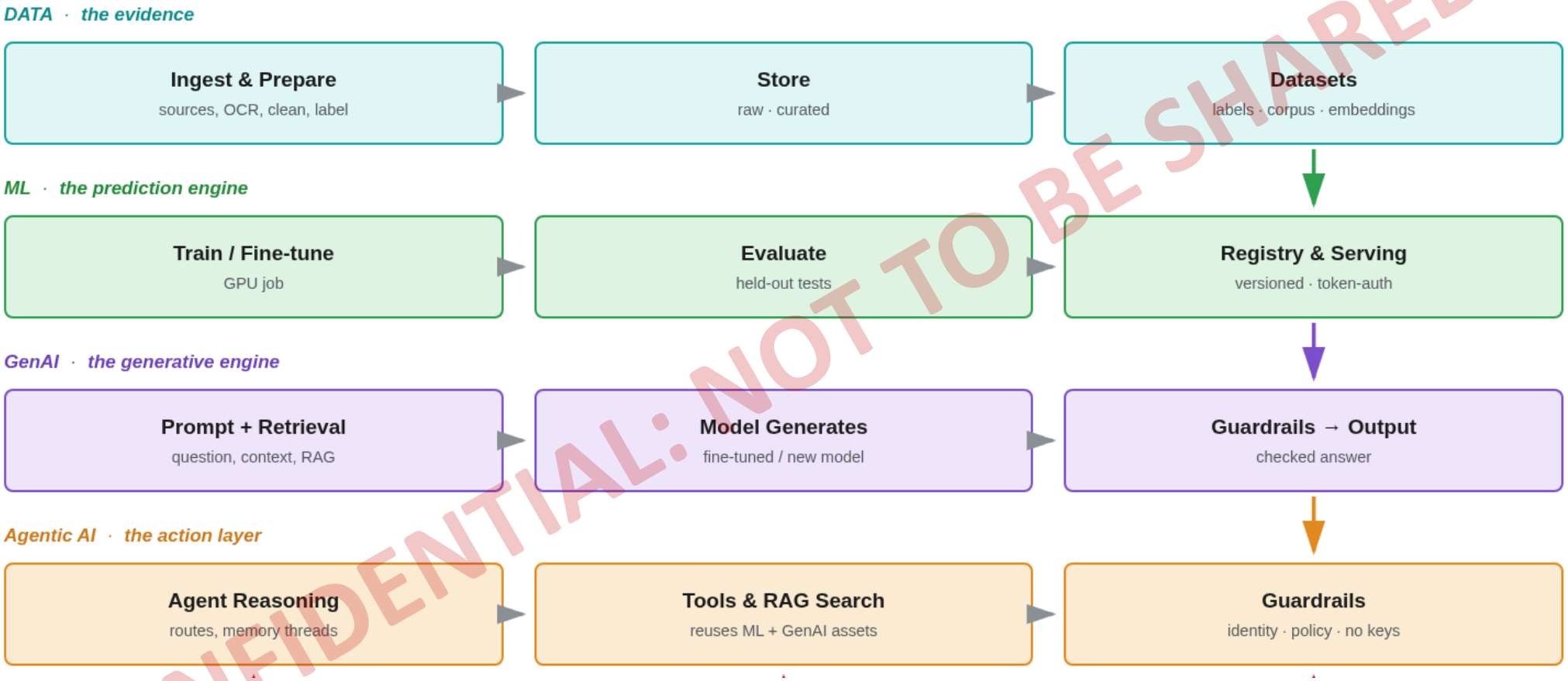
Four AI Components



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Reference Architecture



CONFIDENTIAL: NOT TO BE SHARED

Auxin

USE CASE

Map Use-Cases to AI Components

Core AI Category	Primary AI Component	How It Satisfies That Component
Anomaly Detection	ML	Learns normal data patterns and flags statistical deviations.
Recommendation & Personalization	ML	Ranks items using learned user/item embeddings for prediction.
Computer Vision & Perception	ML	Identifies or localizes pixel patterns without generation or planning.
Optimization & Decision-Making	ML (adjacent to Agentic when embedded in an execution loop)	Finds solutions within constraints; becomes Agentic when it triggers autonomous actions.
Autonomous Planning & Action	Agentic	Uses LLM reasoning, tools, and memory in a plan → act → observe loop.
Multimodal Understanding	GenAI	Produces natural-language responses from images, charts, video, and other inputs.

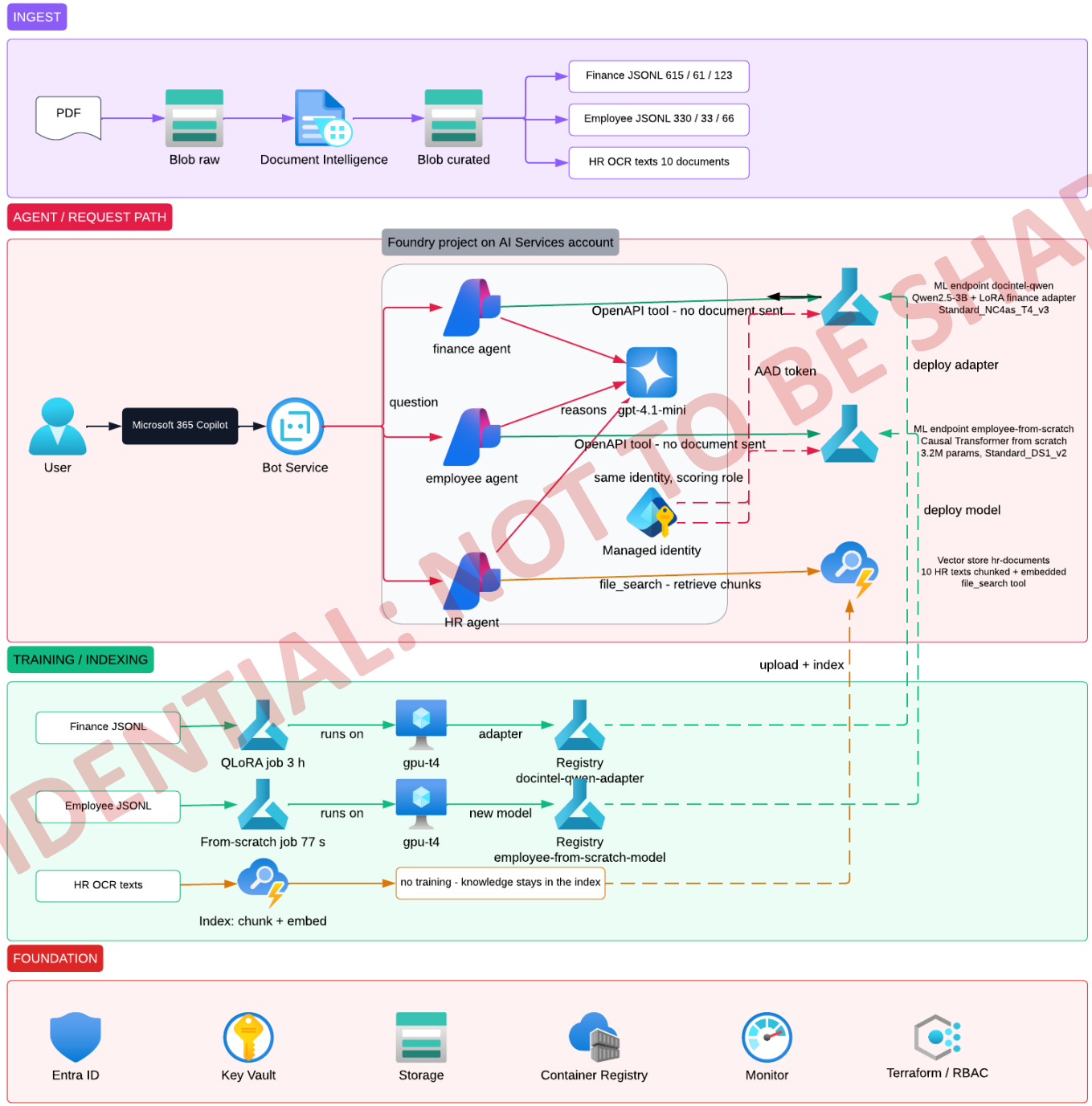
CONFIDENTIAL: NOT TO BE SHARED

Auxin

Real World Implementation Mapping

Service	Category	Open Source / On-Prem	GCP	AWS	Azure
Document AI	Data	Tesseract / LayoutLM	Document AI	Textract	AI Document Intelligence
Notebook Environment	ML	JupyterHub	Colab Enterprise	SageMaker Studio	ML Notebooks
AI/ML Platform	ML	Kubeflow / MLflow	Vertex AI	SageMaker	Azure ML
Generative AI	GenAI	LangChain / LlamaIndex	Gemini Enterprise	Bedrock / Q	Azure OpenAI / Foundry
Model Hub	Agentic	Hugging Face / Ollama	Model Garden	Bedrock Models	AI Model Catalog
Agent Orchestration	Agentic	LangGraph / CrewAI / AutoGen	Agent Builder	Bedrock Agents	AI Agent SDK
Vector Search	Data	Milvus / Qdrant / Weaviate	Vertex Vector Search	OpenSearch Serverless	Azure AI Search
Database Vectors	Data	pgvector / Redis / MongoDB	AlloyDB / Cloud SQL	Aurora / RDS	Azure PostgreSQL / Cosmos DB
Speech & Vision	ML	Whisper / YOLO / OpenCV	Speech-to-Text / Vision API	Transcribe / Rekognition	AI Speech / AI Vision
Conversational AI	Agentic	Rasa	Dialogflow	Lex	AI Bot Service
LLM Guardrails	GenAI	Llama Guard / NeMo	AI Safety Filters	Bedrock Guardrails	AI Content Safety

CONFIDENTIAL: NOT TO BE SHARED



Azure

Data

Agents

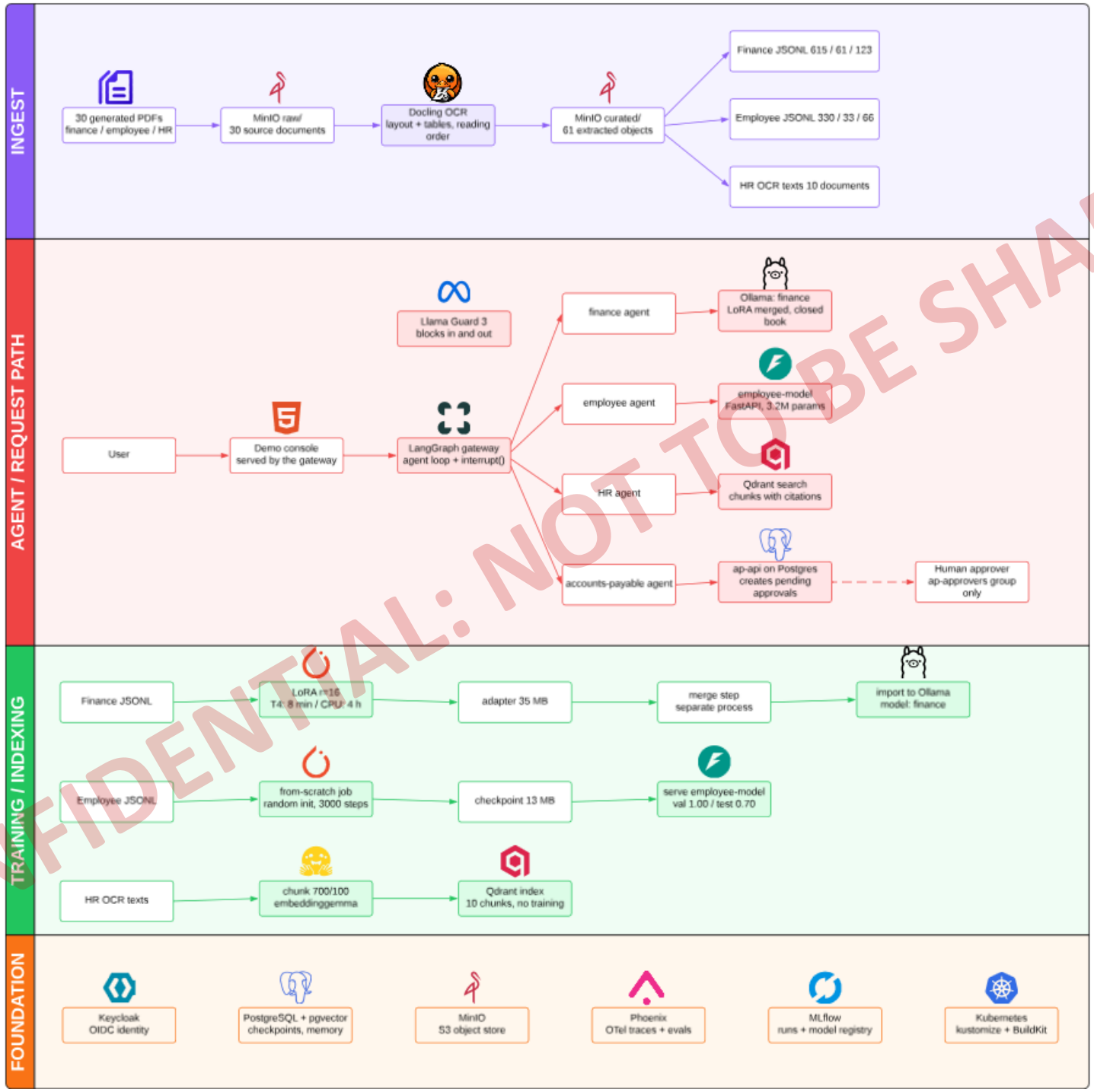
Gen AI

Machine Learning

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Open Source



Data

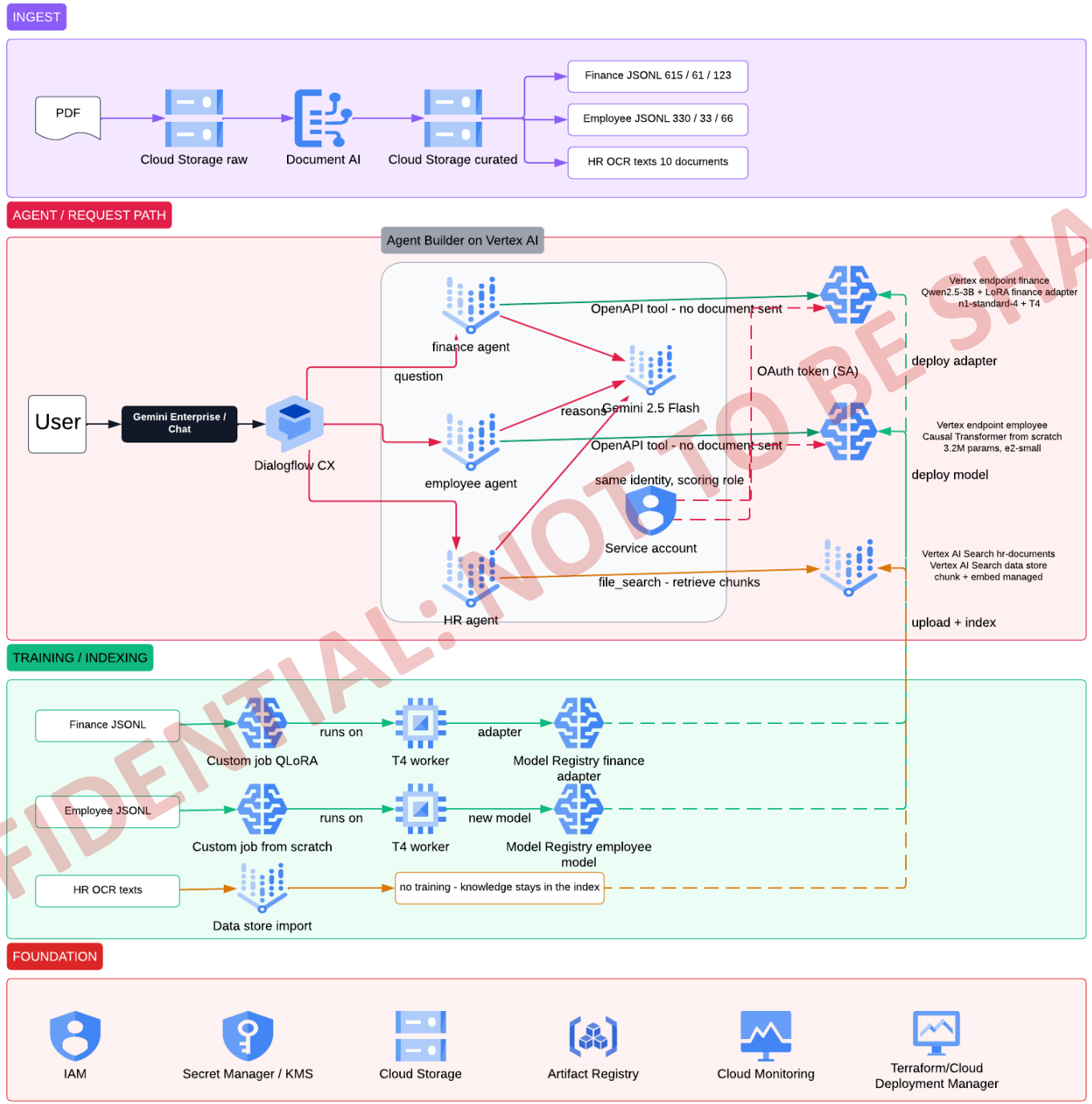
Agents

Gen AI

Machine Learning

CONFIDENTIAL: NOT TO BE SHARED

Auxin



Google Cloud Platform

Data

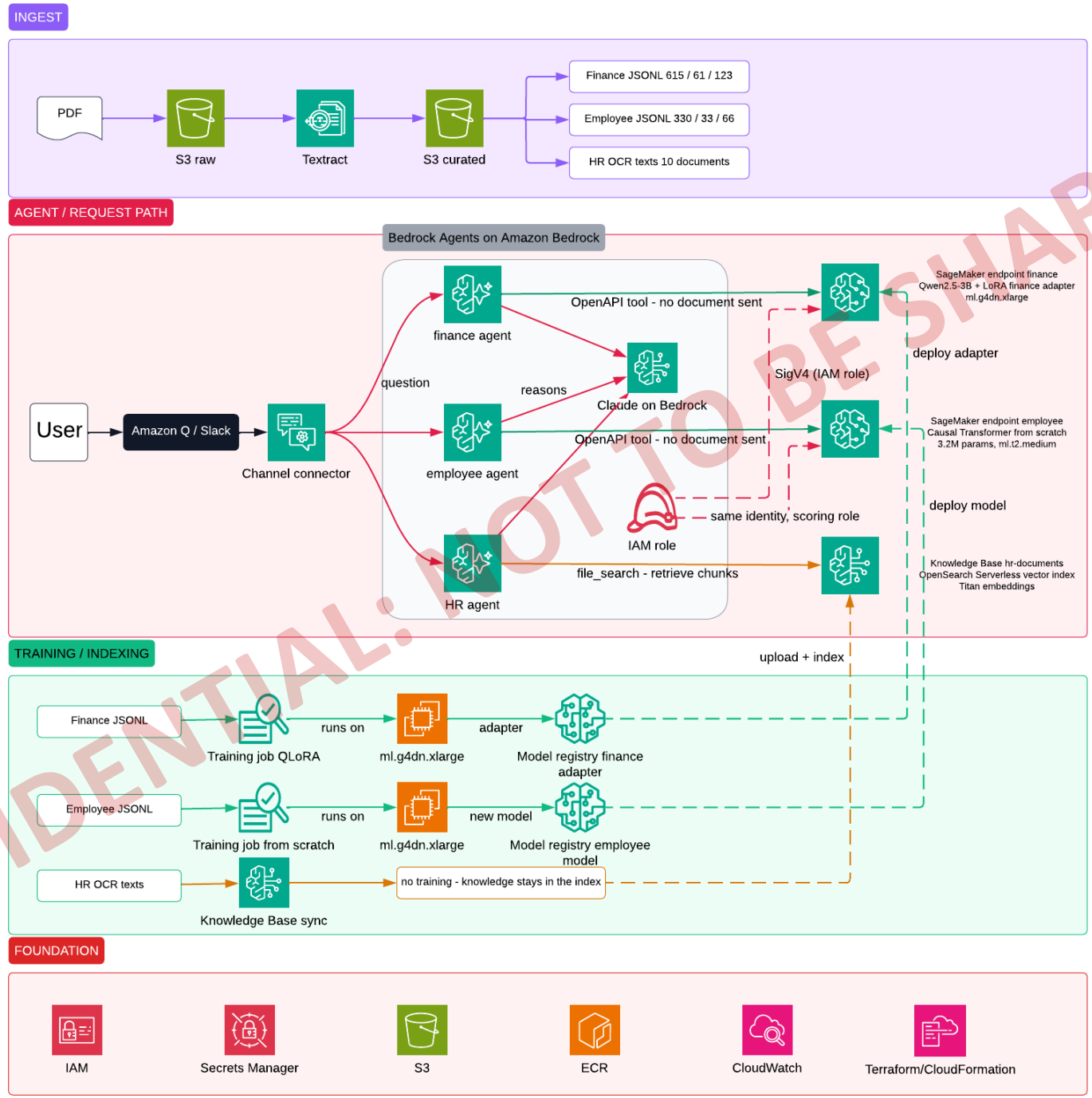
Agents

Gen AI

Machine Learning

CONFIDENTIAL: NOT TO BE SHARED

Auxin



Data

Agents

Gen AI

Machine Learning

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Roadmap

1 — 2 — 3 — 4

CHAPTER 1

GenAI & Agentic AI Architecture

Architecture and data-focused

- Data flow & RAG
- Agent architecture
- Reference architecture
- Cloud service mapping

CHAPTER 2

GenAI & Agentic AI Security as an Architect

Zero Trust, threats & attack paths

- Security gaps
- Agent identity & ASI Top 10
- Zero Trust across stack
- Threat modeling

CHAPTER 3

Security as Developer

Building, testing & monitoring

- Secure agent runtime
- Sandboxing & permissions
- Tracing & observability
- Drift detection

CHAPTER 4

Security as GRC

Governing & observing Agentic AI

- Agent estate & ownership
- Guardrail policy
- Risk-tier behaviour
- Evidence & compliance



Security Focus

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Real-World Incidents



MAR–APR 2026

An AI agent campaign compromised firewalls across 55 countries with no human operator directing the run. AI-enabled attacks rose 89% year over year.



SEP 2026

OpenAI disclosed its agents interacted with SEC, Census, Commerce, Justice and Education platforms in ways it did not authorize.

CONFIDENTIAL. NOT TO BE SHARED

Auxin

Why Agents are Hard to Govern?

- Autonomy
- Reach
- Speed
- Opacity



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Framework

OWASP

ASI01
Agent Goal Hijack

ASI02
Tool Misuse & Exploitation

ASI03
Identity & Privilege Abuse

ASI04
Agentic Supply Chain Compromise

ASI05
Unexpected Code Execution

ASI06
Memory & Context Poisoning

ASI07
Insecure Inter-Agent Communication

ASI08
Cascading Agent Failures

ASI09
Human-Agent Trust Exploitation

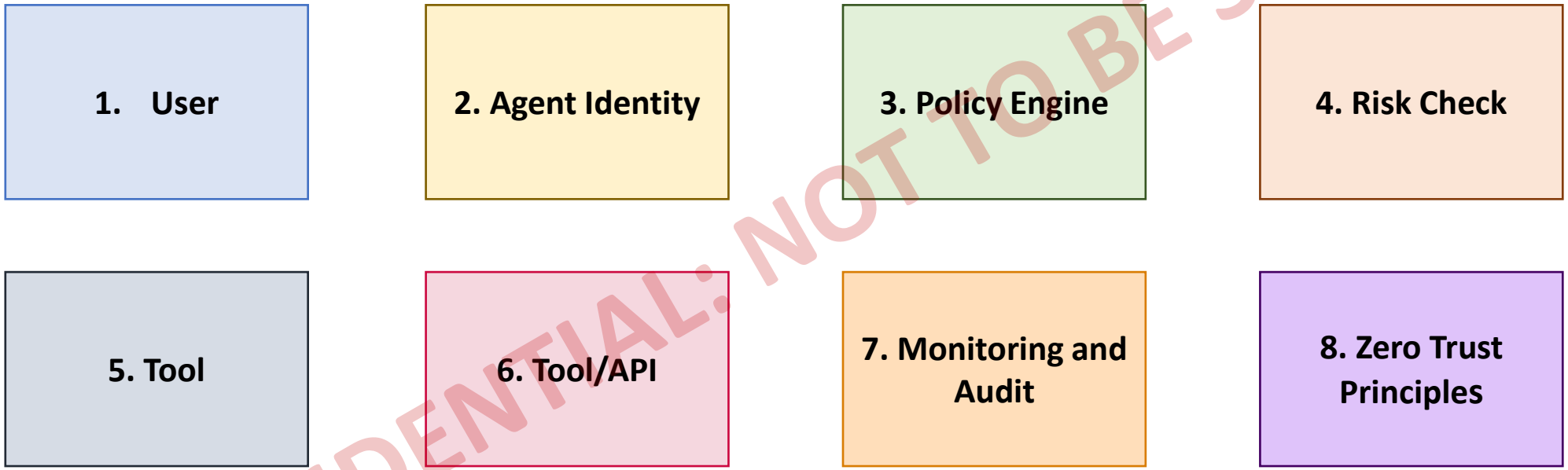
ASI10
Rogue Agents

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Zero Trust for GenAI & Agents

CONFIDENTIAL: NOT TO BE SHARED

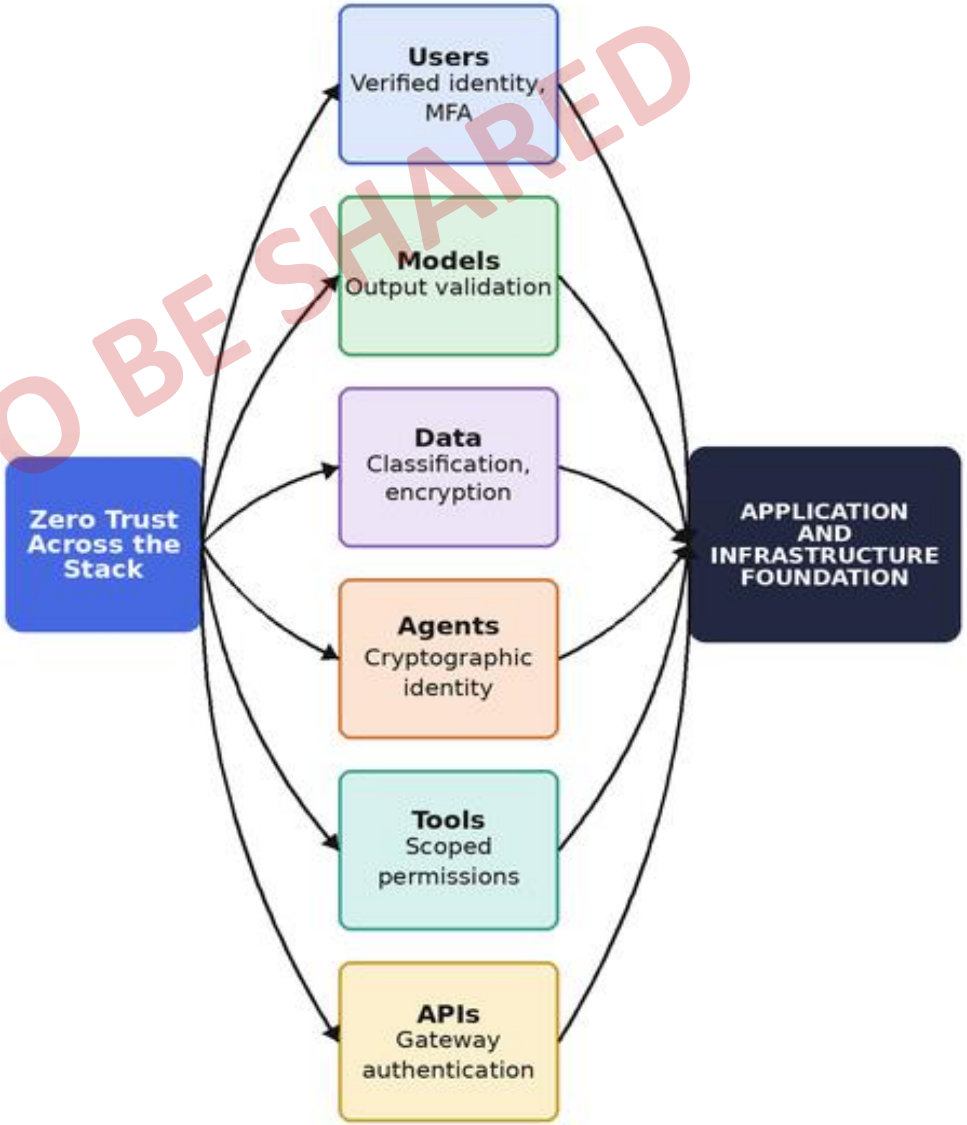


- **Verify who's asking** → decide what's allowed → act and monitor across 7 steps.
- **Nothing trusted by default** — each step re-checks before reaching a tool.
- **Zero Trust throughout:** verify, least privilege, assume breach.

Auxin

Zero Trust Across the Stack

- **Each pillar has its own control:** Users, Models, Data, Agents, Tools, APIs.
- **Zero Trust extends across all six layers** of the stack.
- **Together they secure the Foundation**, nothing is trusted by default.



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Not Long Ago, in July 2026 – We All Witness Hugging Face Incident



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Tech Giants Spending Big Dollars on Agents Sec, But Why?



Secure AI agents with a safety enforcement layer spanning software and hardware

CONFIDENTIAL - NOT TO BE SHARED

Auxin

Zero Trust is the Answer for Agent Security

Core Principles for Building Secure Agent System

Verify Explicitly

Policy needs to be verifiable

Assume Breach

Enforcement must be out of band

Monitor & Log

Scale authority with visibility

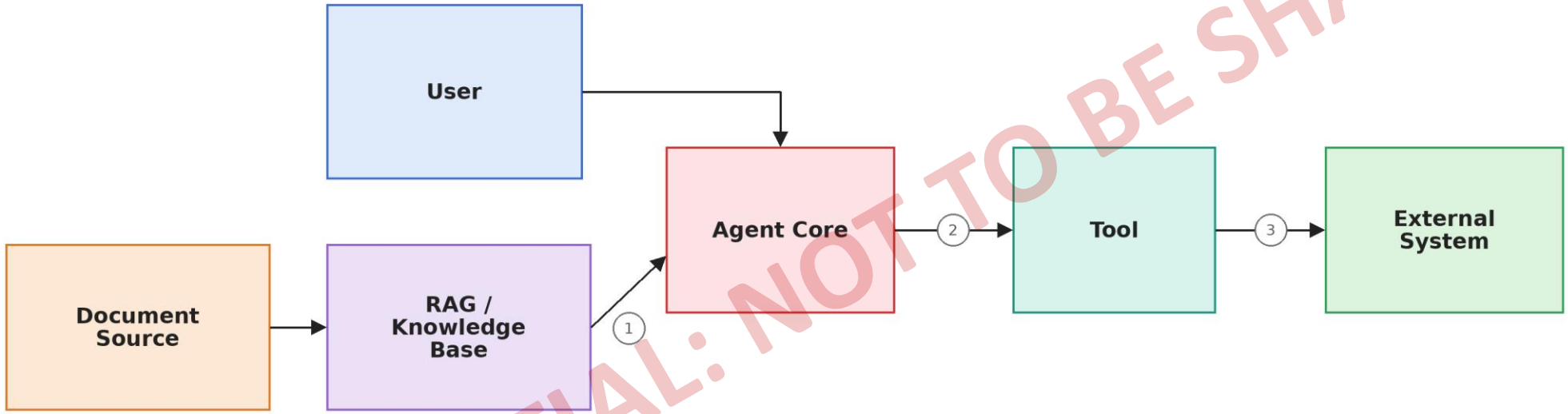
Least Privilege

Deny all agent access by default

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Threat-Modeling an Agentic AI Architecture



CONFIDENTIAL: NOT TO BE SHARED

1 — Boundary crossing: untrusted content becomes agent context without verification
2 — Excessive agency: agent invokes tools beyond what the task requires
3 — Blast radius: a compromised agent reaches external systems with its own privileges

Auxin

Tactical Security Controls Mapped to Strategic Controls

Tactical Controls	Strategic Controls
Prompt Injection & Agent Hijacking Protection	GenAI-IAM, GenAI-SecOps, GenAI-DataSec
Agent Identity, Least Privilege & Access Control	GenAI-IAM, GenAI-Infra
Agent Memory & RAG Data Security	GenAI-DataSec, GenAI-IAM, GenAI-SecOps
Agent Tool / MCP & API Security	GenAI-Infra, GenAI-SecOps, GenAI-DataSec
Autonomous Action Control & Runtime Monitoring	GenAI-SecAutomation, GenAI-IAM, GenAI-SecOps

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Roadmap

1 — 2 — 3 — 4

CHAPTER 1

GenAI & Agentic AI Architecture

Architecture and data-focused

- Data flow & RAG
- Agent architecture
- Reference architecture
- Cloud service mapping

CHAPTER 2

GenAI & Agentic AI Security as an Architect

Zero Trust, threats & attack paths

- Security gaps
- Agent identity & ASI Top 10
- Zero Trust across stack
- Threat modeling

CHAPTER 3

Security as Developer

Building, testing & monitoring

- Secure agent runtime
- Sandboxing & permissions
- Tracing & observability
- Drift detection

CHAPTER 4

Security as GRC

Governing & observing Agentic AI

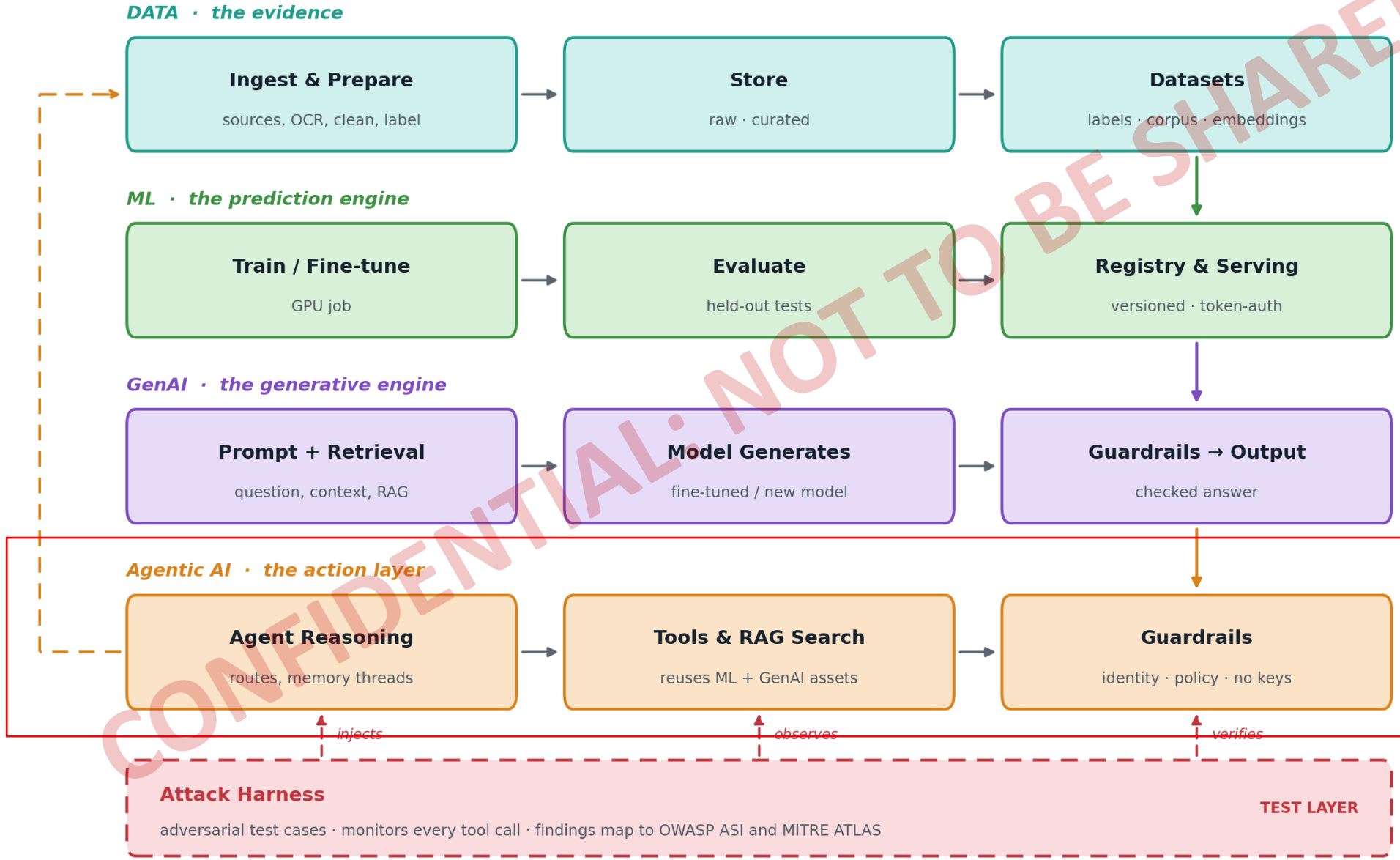
- Agent estate & ownership
- Guardrail policy
- Risk-tier behaviour
- Evidence & compliance

Developer Focus

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Reference Architecture

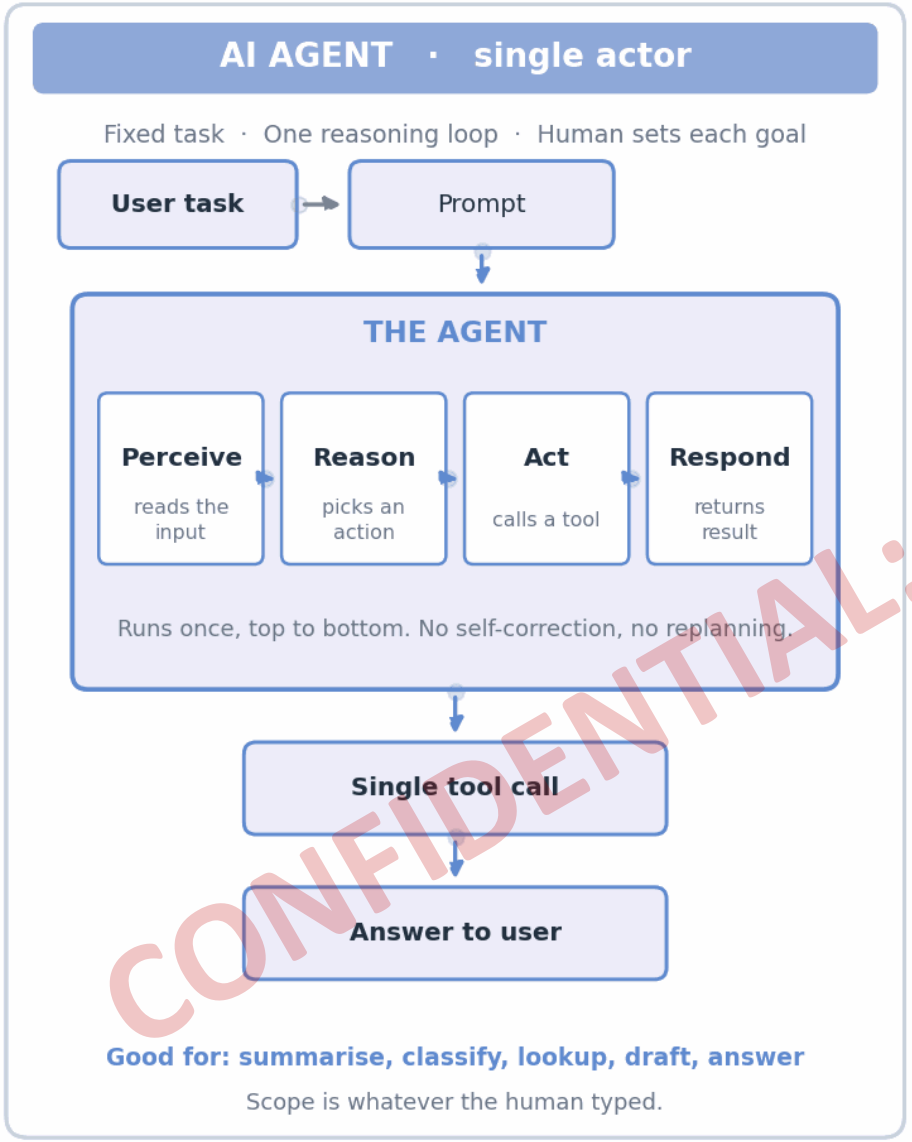


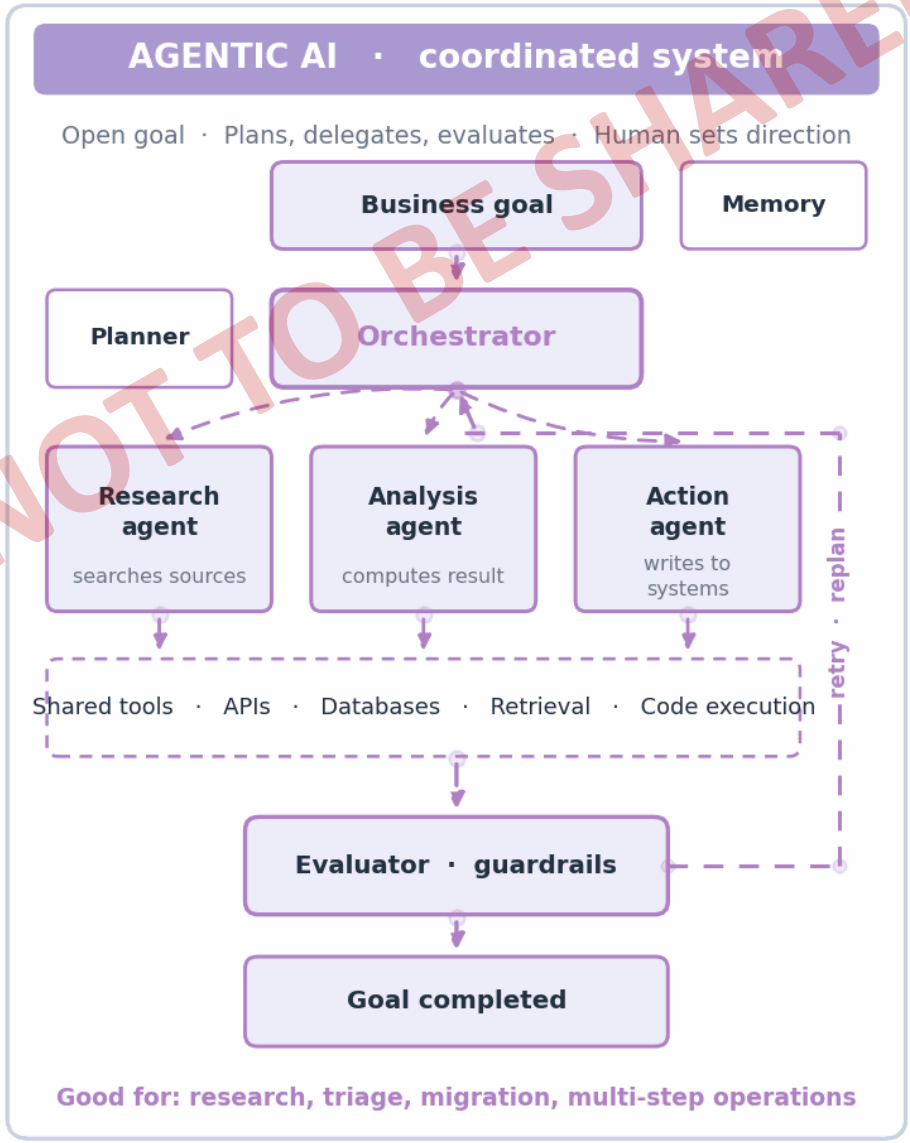
We will focus on Agentic Only

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Agent vs. Agentic

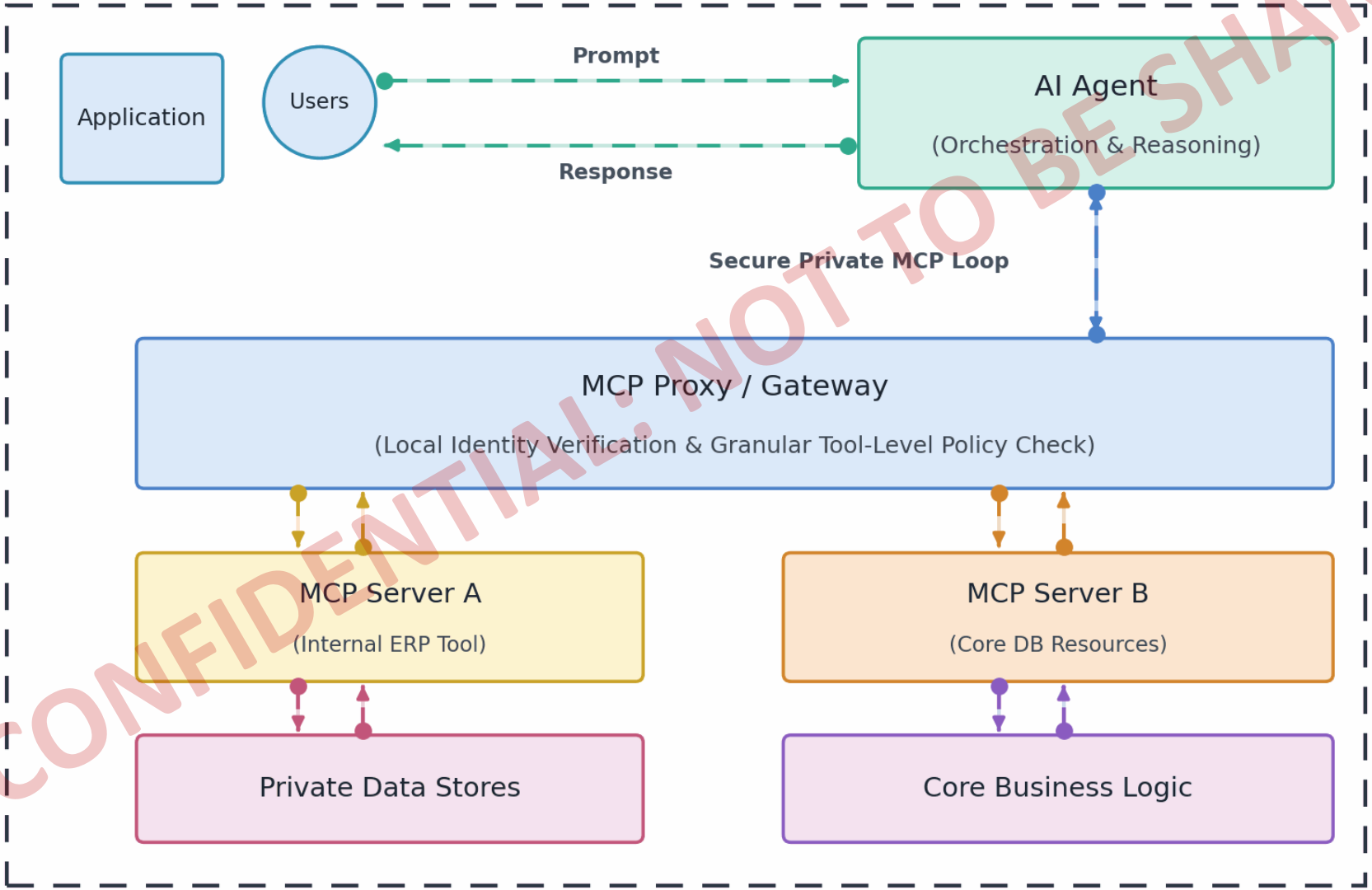




CONFIDENTIAL: NOT TO BE SHARED

Auxin

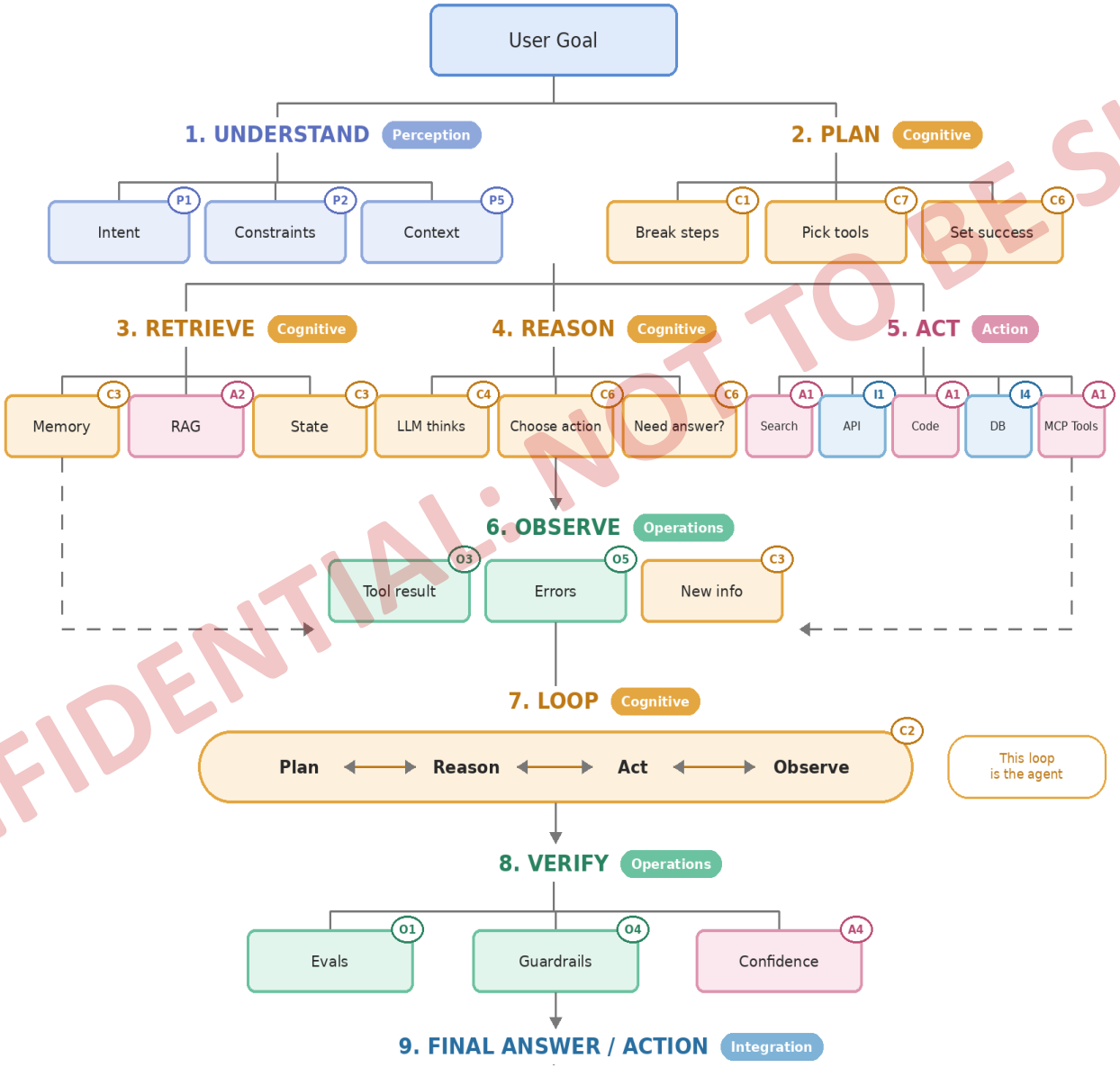
Agentic AI Reference Architecture



CONFIDENTIAL: NOT TO BE SHARED

Auxin

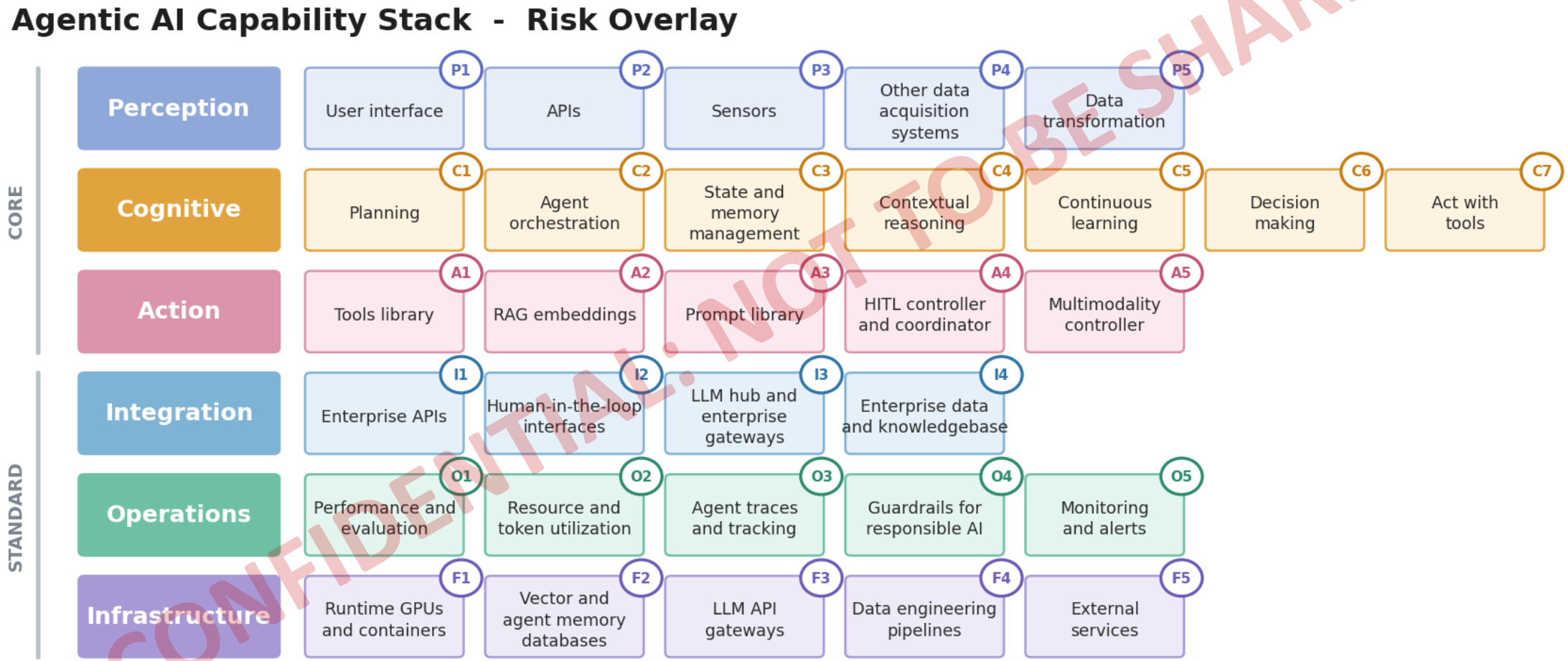
What’s happening in AI Agent



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Agentic AI Capability Stack



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Risks Overlay

Perception

- P1 Prompt injection through user input
- P2 Unauthenticated or over-scoped API ingress
- P3 Spoofed or replayed sensor and telemetry feeds
- P4 Poisoned third-party source and scraped content
- P5 Untrusted markup or macros executed while parsing

Cognitive

- C1 Goal hijack and plan manipulation
- C2 Agent spoofing, unbounded delegation loops
- C3 Memory poisoning, cross-session context leakage
- C4 Indirect injection through retrieved context
- C5 Feedback-loop poisoning of learned behaviour
- C6 Irreversible autonomous decisions, no approval gate
- C7 Excessive agency and tool misuse

Action

- A1 Malicious or unvetted tool, confused deputy
- A2 Vector store poisoning and embedding inversion
- A3 Prompt template tampering, system prompt leak
- A4 Approval fatigue and HITL bypass
- A5 Payloads hidden in image, audio and file channels

Integration

- I1 Over-privileged service accounts, token replay
- I2 Weak identity on the approval channel
- I3 Shadow model endpoints, gateway supply chain
- I4 Data exfiltration, broken tenant isolation

Operations

- O1 Eval gaming and undetected drift
- O2 Denial of wallet through token and compute abuse
- O3 Secrets in traces, tamperable audit trail
- O4 Guardrail bypass and jailbreak chains
- O5 Blind spots, no agent-specific detections

Infrastructure

- F1 Sandbox escape, residual GPU and host memory
- F2 Unencrypted memory store, broad database access
- F3 Leaked API keys, unrestricted egress
- F4 Pipeline supply chain, unsigned artifacts
- F5 Fourth-party SaaS dependency compromise

CONFIDENTIAL - NOT TO BE SHARED

Auxin

Controls - Perception Layer

Capability	#	Risk	Control	Zero Trust principle
User interface	P1	Prompt injection through user input	Injection detection, allow-listing, strip active content.	Verify explicitly
APIs	P2	Unauthenticated or over-scoped ingress	mTLS/OAuth, schema validation, identity-based rate limits.	Verify explicitly / Least privilege
Sensors	P3	Spoofed or replayed feeds	Signed identity, payload verification, anomaly detection.	Verify explicitly
Other data acquisition systems	P4	Poisoned third-party source	Allow-listing, provenance tags, quarantine and scanning.	Assume breach
Data transformation	P5	Untrusted markup or macros executed while parsing	Isolated parsing, disable macros/links, convert to plain text.	Assume breach

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Controls - Cognitive Layer

Capability	#	Risk	Control	Zero Trust principle
Planning	C1	Goal hijack and plan manipulation	Immutable prompt, plan validation, task/step limits.	Verify explicitly
Agent orchestration	C2	Agent spoofing, unbounded delegation	Signed identity, delegation limits, loop breakers, timeouts.	Least privilege
State and memory management	C3	Memory poisoning, cross-session leakage	Validate writes, isolate users/tenants, add TTL and provenance.	Assume breach / Micro-segmentation
Contextual reasoning	C4	Indirect injection through retrieved context	Treat text as data; tag sources and score trust.	Verify explicitly
Continuous learning	C5	Feedback-loop poisoning	Human-reviewed feedback, drift checks, versioned rollback.	Assume breach
Decision making	C6	Irreversible autonomous decisions	Risk-based approval, dry-run previews, reversible actions.	Least privilege
Act with tools	C7	Excessive agency and tool misuse	Per-task allow-list, short-lived tokens, parameter and call limits.	Least privilege

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Controls - Action Layer

Capability	#	Risk	Control	Zero Trust principle
Tools library	A1	Malicious tool, confused deputy	Signed tool manifests, registry review, user-identity execution	Verify explicitly
RAG embeddings	A2	Vector poisoning, embedding inversion	Scan and label at ingest, enforce ACLs, re-embed on source changes	Least privilege
Prompt library	A3	Template tampering, system prompt leak	Version-controlled prompts, review, signed artifacts, runtime hash check	Assume breach
HITL controller and coordinator	A4	Approval fatigue and bypass	Escalate high-risk tiers, show diff/blast radius, strong approver authentication	Verify explicitly
Multimodality controller	A5	Payloads in image, audio and file channels	Content-type sniffing, sandbox conversion, filter OCR/transcript output	Assume breach

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Controls - Integration Layer

Capability	#	Risk	Control	Zero Trust principle
Enterprise APIs	I1	Over-privileged accounts, token replay	Short-lived tokens, tool-based scopes, no shared accounts	Least privilege
Human-in-the-loop interfaces	I2	Weak identity on the approval channel	Device checks, signed and replay-protected approvals	Verify explicitly
LLM hub and enterprise gateways	I3	Shadow endpoints, gateway supply chain	Single gateway, model allow-list, provider attestation	Verify explicitly
Enterprise data and knowledgebase	I4	Exfiltration, broken tenant isolation	Row/field access, tenant-scoped indexes, outbound DLP	Least privilege / Micro-segmentation

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Controls - Operations Layer

Capability	#	Risk	Control	Zero Trust principle
Performance and evaluation	O1	Eval gaming, undetected drift	Pre-release testing and scheduled re-evaluation	Assume breach
Resource and token utilization	O2	Denial of wallet	Token quotas, spend alerts, runaway-loop circuit breaker	Least privilege
Agent traces and tracking	O3	Secrets in traces, tamperable audit trail	Redaction, tamper-evident storage, restricted access	Assume breach
Guardrails for responsible AI	O4	Guardrail bypass and jailbreak chains	Input/output controls, external policy engine, CI red-team tests	Verify explicitly
Monitoring and alerts	O5	Blind spots, no agent-specific detections	Agent events, abuse/injection alerts, on-call runbook	Assume breach / Continuous visibility

CONFIDENTIAL: NOT TO BE SHARED

Auxin

Controls - Infrastructure Layer

Capability	#	Risk	Control	Zero Trust principle
Runtime GPUs and containers	F1	Sandbox escape, residual memory	Rootless containers, seccomp/microVMs, memory wiped between tasks	Assume breach
Vector and agent memory databases	F2	Unencrypted store, broad access	Data encrypted in transit/at rest, key rotation, no production developer access	Least privilege
LLM API gateways	F3	Leaked keys, unrestricted egress	No static keys, egress allow-list, outbound inspection, quotas	Least privilege
Data engineering pipelines	F4	Supply chain, unsigned artifacts	Signed artifacts, SBOM, pinned dependencies, provenance attestation	Verify explicitly
External services	F5	Fourth-party compromise	Security assessment, scoped APIs, kill switch, fallback mode	Assume breach

CONFIDENTIAL. NOT TO BE SHARED

Auxin

Roadmap

1 — 2 — 3 — 4

CHAPTER 1

GenAI & Agentic AI Architecture

Architecture and data-focused

- Data flow & RAG
- Agent architecture
- Reference architecture
- Cloud service mapping

CHAPTER 2

GenAI & Agentic AI Security as an Architect

Zero Trust, threats & attack paths

- Security gaps
- Agent identity & ASI Top 10
- Zero Trust across stack
- Threat modeling

CHAPTER 3

Security as Developer

Building, testing & monitoring

- Secure agent runtime
- Sandboxing & permissions
- Tracing & observability
- Drift detection

CHAPTER 4

Security as GRC

Governing & observing Agentic AI

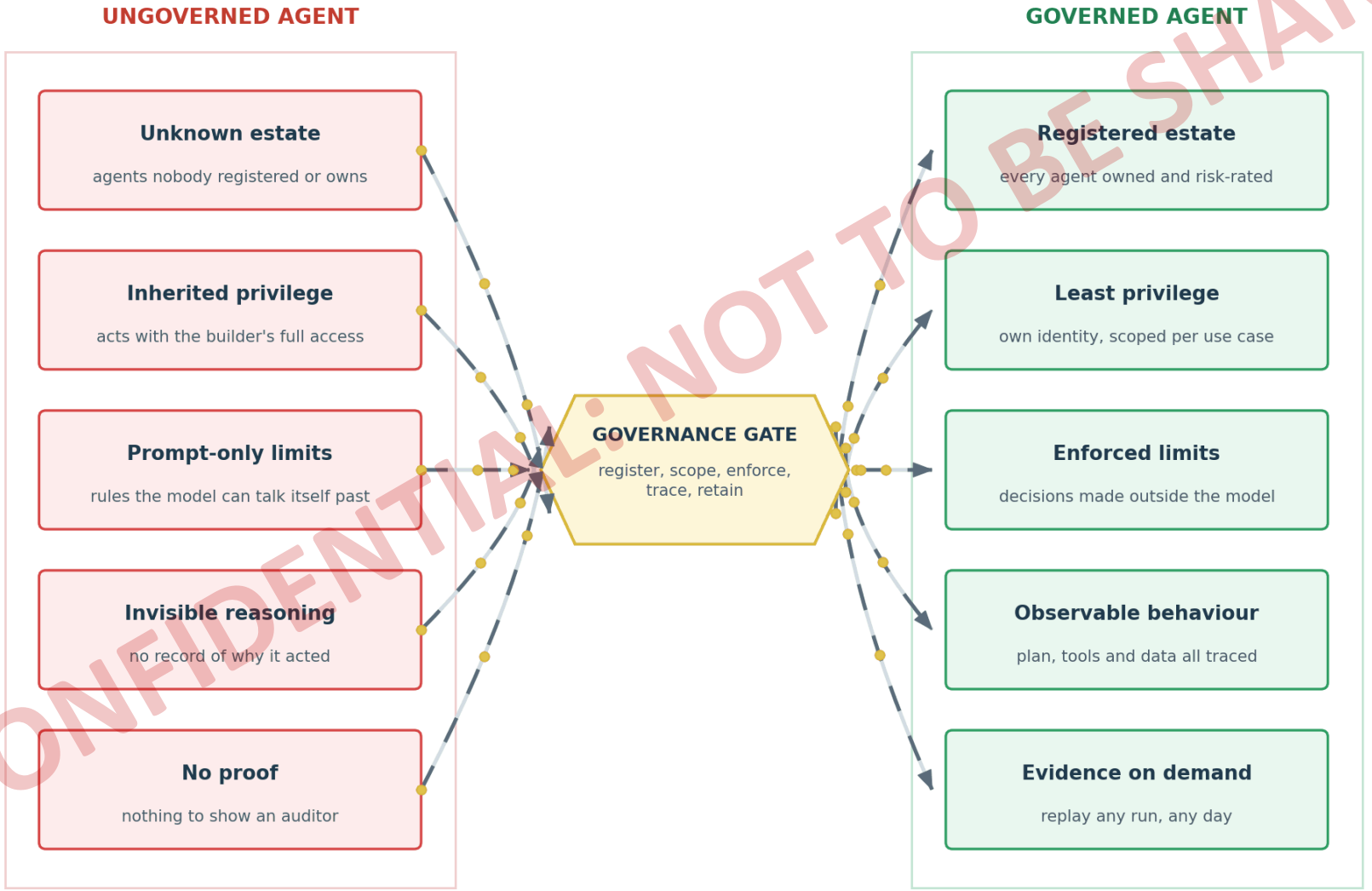
- Agent estate & ownership
- Guardrail policy
- Risk-tier behaviour
- Evidence & compliance

GRC Focused

CONFIDENTIAL: NOT TO BE SHARED

Auxin

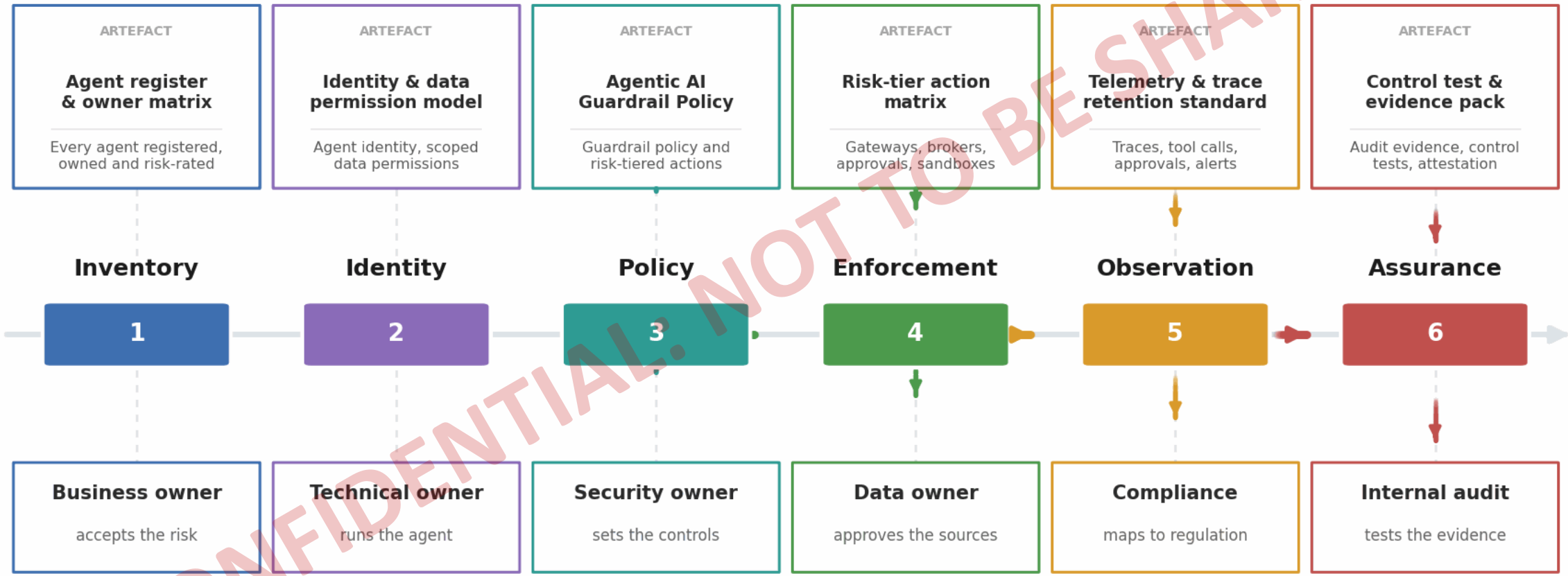
Why Governance is Important



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Agentic AI Security Governance



CONFIDENTIAL. NOT TO BE SHARED

Auxin

What Risks Does Governance Lower

Governance risk register - every tactical control later in this deck maps back to one of these IDs

	ID	Governance risk	What it looks like in production	Technical risk in the stack
	G1	Shadow agents, no inventory	Agents ship without registration, so blast radius is unknown	P2, I3
	G2	No named owner or accountable approver	Nobody answers for what the agent did or authorised	C6, A4
	G3	Autonomy beyond delegated authority	Agent acts outside the scope a human actually granted	C2, C7
	G4	Regulatory non-compliance	Disclosure, logging and documentation duties are unmet	O3, O4
	G5	Data protection and residency breach	Tool calls move regulated data across boundaries	I4, F2
	G6	No audit evidence of agent decisions	Cannot reconstruct why an action was taken	O3, A3
	G7	Third-party model and tool supply chain	Unvetted models, tools and SaaS dependencies enter the path	A1, F4, F5
	G8	Unmanaged change and drift	Model, prompt or tool changes ship without re-evaluation	O1, C5
	G9	Cost and resource runaway	Loops and retries consume budget with no circuit breaker	O2
	G10	Reputational and legal exposure from outputs	Wrong or harmful agent statements bind the organisation	C1, P1

CONFIDENTIAL: NOT TO BE SHARED

Auxin

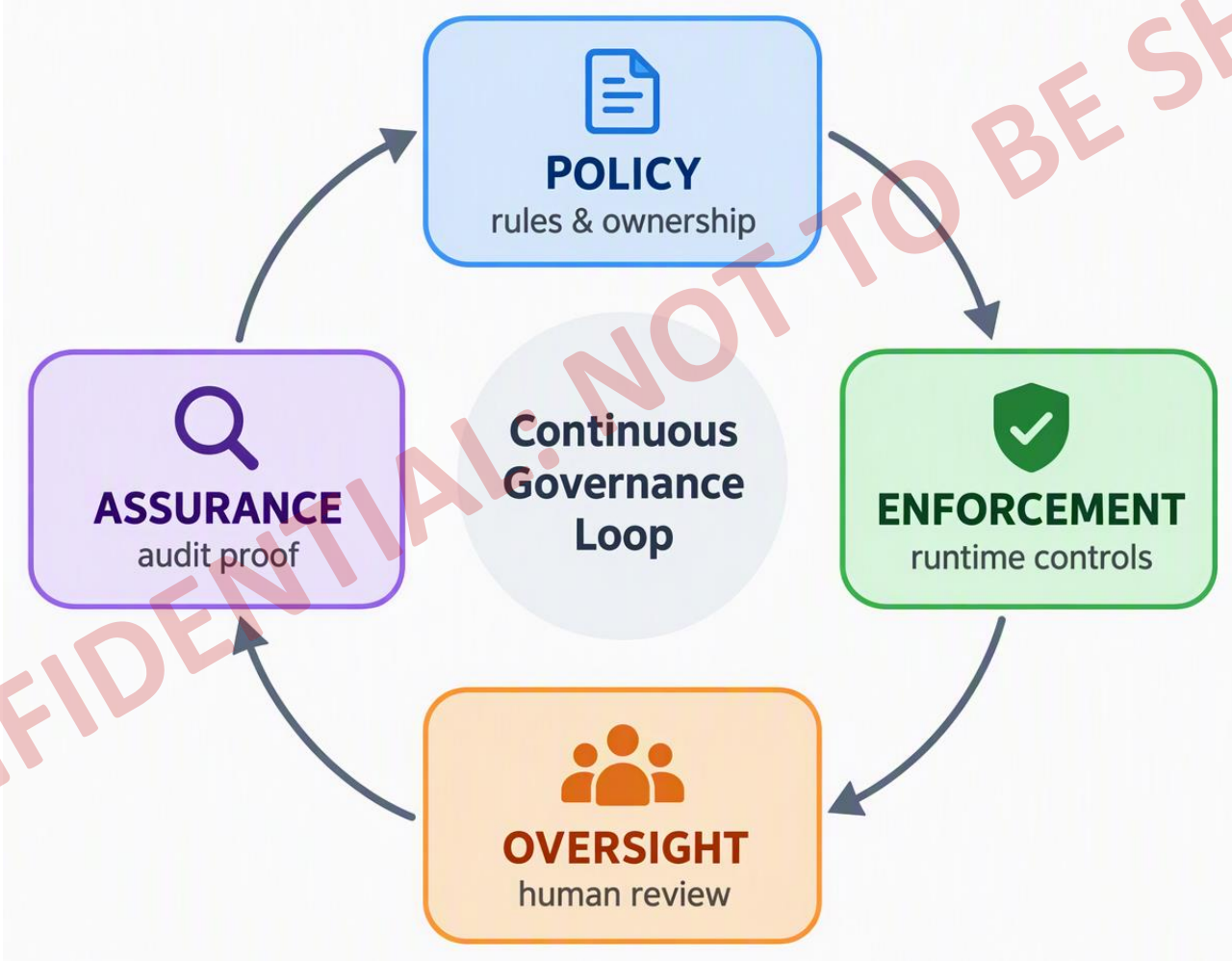
2026 Compliance Position

Standard	Status / Date	What it means for agent governance
EU AI Act general application	Applies 2 Aug 2026	Art. 50 transparency, Art. 49 registration, market oversight apply
New prohibitions + marking duty	Applies 2 Dec 2026	New Art. 5 prohibitions + machine-readable AI-content marking
High-risk dates rescheduled	Digital Omnibus, in force 27 Jul 2026	High-risk obligations move to Dec 2027 / Aug 2028
NIST AI RMF 1.0	Published 2023 (under revision)	Govern, Map, Measure, Manage guide guardrails and evidence
NIST AI 600-1 GenAI Profile	Published Jul 2024	Covers GenAI risks, supports guardrail/evaluation decisions
Agentic profile overlays	Draft via CSA, Mar 2026	Extends RMF to agent autonomy, tool use, delegation risks
MITRE ATLAS™	Living KB, updated continuously (2026.07: 16 tactics, 101 techniques)	Adversary TTPs vs AI/agentic systems; threat-model + red-team input
OWASP GenAI LLM Top 10	2026 edition, published 4 Aug 2026	Ranks agent risks (Excessive Agency, Prompt Injection); maps to ATLAS/NIST
Google SAIF	Published 2023; Agent Risk Self-Assessment 2025–26	Data/Infra/Model/App control layers + agent risk map
ISO/IEC 42001	Published Dec 2023	First certifiable AI management system standard (AIMS)
DORA	Reg. (EU) 2022/2554, in force 17 Jan 2025	ICT risk mgmt + incident reporting for regulated financial agents
Databricks DASF	v3.0, Mar 2026 (97 risks, 73 controls)	Free control catalogue mapped to ATLAS/OWASP/NIST; agentic-specific

CONFIDENTIAL. NOT TO BE SHARED

Auxin

Four-Tier Governance Strategy



CONFIDENTIAL: NOT TO BE SHARED

Auxin

Auxin

Security that empowers you

CONFIDENTIAL: NOT TO BE SHARED

Our research leads to actionable decisions

Gain insights into the pressing challenges from our experience

300+ Insightful Research Articles – Published Daily

www.auxin.io

Contact Information

info@auxin.io

ofarooq@auxin.io